



UnionPay Integrated Circuit Card Specifications

— Product Specifications

Part III Dynamic Password Specification



Version 2014

THIS PAGE IS INTENTIONALLY LEFT BLANK.

Table of Contents

1	Application Scope.....	1
2	Reference.....	2
3	Terms and Definition	3
3.1	INTEGRATED CIRCUIT CARD (IC CARD).....	3
3.2	FINANCIAL IC CARD.....	3
3.3	DYNAMIC PASSWORD	3
3.4	DYNAMIC PASSWORD TERMINAL	3
3.5	APPLICATION CRYPTOGRAM.....	3
3.6	ISSUER APPLICATION DATA (IAD)	3
3.7	APPLICATION TRANSACTION COUNTER (ATC).....	3
3.8	CARD VERIFICATION RESULT (CVR).....	3
3.9	NUMERICAL REPRESENTATION	3
4	Symbols and Acronyms.....	5
5	Principle of Authentication.....	7
5.1	OVERVIEW	7
5.2	CARD FUNCTION DESCRIPTION	7
5.3	CARD READER TERMINAL WORKING PRINCIPLE	8
5.4	ISSUER AUTHENTICATION WORKING PRINCIPLE.....	9
6	Business Process	11
6.1	FUNCTION OVERVIEW	11
6.1.1	<i>Application Selection</i>	<i>11</i>
6.1.2	<i>Initialization of Application</i>	<i>11</i>
6.1.3	<i>Reading Application Data</i>	<i>11</i>
6.1.4	<i>Terminal Action Analysis</i>	<i>11</i>
6.1.5	<i>Generation of Dynamic Password</i>	<i>11</i>
6.1.6	<i>Transaction Completion.....</i>	<i>12</i>
6.2	TRANSACTION FLOW CHART	12

7	Instruction and Implementation Instructions	13
7.1	APPLICATION SELECTION	13
7.1.1	Command Select	13
7.1.2	Relevant Follow-on Flows	13
7.2	APPLICATION INITIALIZATION	14
7.2.1	Command	14
7.2.2	Processing Flow	14
7.2.3	Relevant Pre-processing	14
7.2.4	Relevant Post-processing	14
7.3	READING APPLICATION DATA	15
7.3.1	Command	15
7.3.2	Processing Flow	15
7.3.3	Relevant Pre-processing	15
7.3.4	Relevant Post-processing	15
7.4	TERMINAL ACTION ANALYSIS	15
7.4.1	Overview	15
7.4.2	Command	15
7.4.3	Processing flow	16
7.4.4	Pre-processing	16
7.4.5	Post-processing	16
7.5	GENERATION OF DYNAMIC PASSWORD	16
7.5.1	Command	16
7.5.2	Processing Flow	16
7.5.3	Pre-processing	16
7.5.4	Post-processing	17
7.6	TRANSACTION COMPLETION	17
7.6.1	Overview	17
7.6.2	Pre-processing	17
7.7	DATA REQUIRED IN TRANSACTION PROCESS	17
7.7.1	Definition of data involved in CDOL1, CDOL2 and PDOL	17

7.7.2 CVR Data Definition.....	18
8 Dynamic Password Structure and Display	20
8.1 ENCRYPTION ALGORITHM	20
8.2 CONSTRUCTION OF RELEVANT DATA FOR DYNAMIC PASSWORD	20
8.3 VALID BIT SELECTION OF DYNAMIC PASSWORD	20
8.4 ATC XOR	21
8.5 SHIFTING RULE FOR VALID BITS.....	21
8.6 DYNAMIC PASSWORD DISPLAY.....	22
9 Issuer Authentication Service.....	23
9.1 INTRODUCTION OF AUTHENTICATION SERVICE.....	23
9.2 BASIC FRAMEWORK DIAGRAM OF AUTHENTICATION SERVICE.....	24
9.3 AUTHENTICATION SERVER REFERENCE FLOWCHART	25
9.4 LOSS OF SYNCHRONISM PROCESSING	26
9.5 DATA MANAGEMENT	26
9.5.1 Card Data	26
9.5.2 Terminal data.....	28
9.6 ALGORITHM	28
9.7 RISK MANAGEMENT.....	28
10 Other Requirements.....	29
10.1 CARD READER HARDWARE REQUIREMENTS	29
10.1.1 Display Screen	29
10.1.2 Input.....	29
10.1.3 IC card Reader	29
10.1.4 Battery	29
10.2 CARD READER SOFTWARE REQUIREMENTS.....	29
10.3 CARD READER SECURITY REQUIREMENTS	29
10.4 BALANCE INQUIRY	29
Appendix A Application mode recommendation	30
A.1 EVENT (OR DEFAULT) AUTHENTICATION MODE.....	30
A.2 CHALLENGE AUTHENTICATION MODE.....	31

A.3 TRANSACTION SIGNATURE MODE	32
A.4 INPUT TRANSFER ACCOUNT	33
A.5 APPLICATION EXAMPLE:	34

1 Application Scope

This book applies to all UPI participants.

2 Reference

The clauses in the following documents become the clauses in this standard after being quoted by this standard. For the dated references, all their subsequent modifications (excluding the contents of corrigendum) or the revisions are not applicable to this standard. However, all the parties reaching an agreement according to this standard are encouraged to study whether the latest version of these documents can be used. For the undated references, their latest versions are applicable to this standard.

UICS Basic Specification Part 1: Debit/Credit Application Overview

UICS Basic Specification Part 2: Debit/Credit Application Card Specification

UICS Basic Specification Part 4: Debit/Credit Application Security Specification

3 Terms and Definition

3.1 Integrated Circuit Card (IC card)

Card installed with one or more integrated circuits to execute process and storage functions.

3.2 Financial IC Card

IC card with debit/credit application in line with UICS Specifications .

3.3 Dynamic Password

Dynamic password is an unpredictable random number combination generated according to special algorithm and each PIN can be used only once.

3.4 Dynamic Password Terminal

Devices using financial IC card to generate dynamic password.

3.5 Application Cryptogram

Application cryptogram refers to the 8 digit cryptogram generated by card using application cryptogram sub-key by encrypting data from terminal and card after sending GENERATE AC command. Such data includes partial data identified by card risk management parameter list objects and dynamic data in the card. Types of cryptogram include TC (offline approval), ARQC (online) and AAC (denial).

3.6 Issuer Application Data (IAD)

Issuer application data is the mandatory data for UICS, which will be used to transmit data defined by UICS to terminals, and then released into online request message or settlement message. Data elements included in the data are:

Length indicator, scattered key index, cryptogram version information, card verification result, algorithm identifier, issuer self-defined data (optional).

3.7 Application Transaction Counter (ATC)

Transaction volume processed after card personalization shall be used in terminal frequency check.

3.8 Card Verification Result (CVR)

Verification result indicator set up according to offline processing result of current and last transaction.

3.9 Numerical Representation

The specification adopts the following values and symbols:

Decimal values are expressed as the numbers themselves (for example: digit 1)

Hexadecimal values are expressed as values with quotation marks, with x in front (for example: value x'01')

Binary values are expressed as values with quotation marks, with b in front (for example: value b'00000001' or b'1').

Bit 1 indicates low order (0x01), Bit 8 indicates high order (0x80).

4 Symbols and Acronyms

The following table of symbols and acronyms is applicable for this Standard:

AAC

Application Authentication Cryptogram

AC

Application Cryptogram

AFL

Application File Locator

AID

Application Identifier

AIP

Application Interchange Profile

ARQC

Authorization Request Cryptogram

ATC

Application Transaction Counter

CDOL

Card Risk Management Data Object List

CVR

Card Verification Results

CVN

Card Verification Number

DDA

Dynamic Data Authentication, prevents false card in offline authentication, card generates RSA signature for specific data in transaction which could be used in terminal verification.

DKI

Derivation Key Index

FCI

File Control Information, responded and returned by card when reader or terminal selects card application (using SELECT command)

GPO

GET PROCESSING OPTIONS

ISO

International Organization for Standardization

PDOL

Processing Options Data Object List. A list of terminal data objects required by card.

PIN

Personal Identification Number

PSE

Payment System Environment

RFU

Reserved for Future Use

SDA

Static Data Authentication

SFI

Short File Identifier

TC

Transaction Certificate, application cryptogram generated when accepting transaction.

TLV

Tag, Length, Value

UDK

The unique scattered key, used to calculate process key and generate application cryptogram.

5 Principle of Authentication

5.1 Overview

The specification involves a dynamic password authentication technology based on financial IC card. Its fundamental principle is based on card generating response using the data source sent by card reader terminal by means of GENERATE AC and processing the response result to form the dynamic password used in user authentication. In user authentication, dynamic password will be uploaded to the authentication server of the issuer. Authentication server processes the uploaded dynamic password. While withdrawing partial data for comparison authentication afterwards on the one hand, it will rebuild the GENERATE AC process similar to the card using the information included in dynamic password and obtain partial data used in authentication after processing. Compare the two partial data and use the comparison result in authentication.

Specific procedure is shown below:

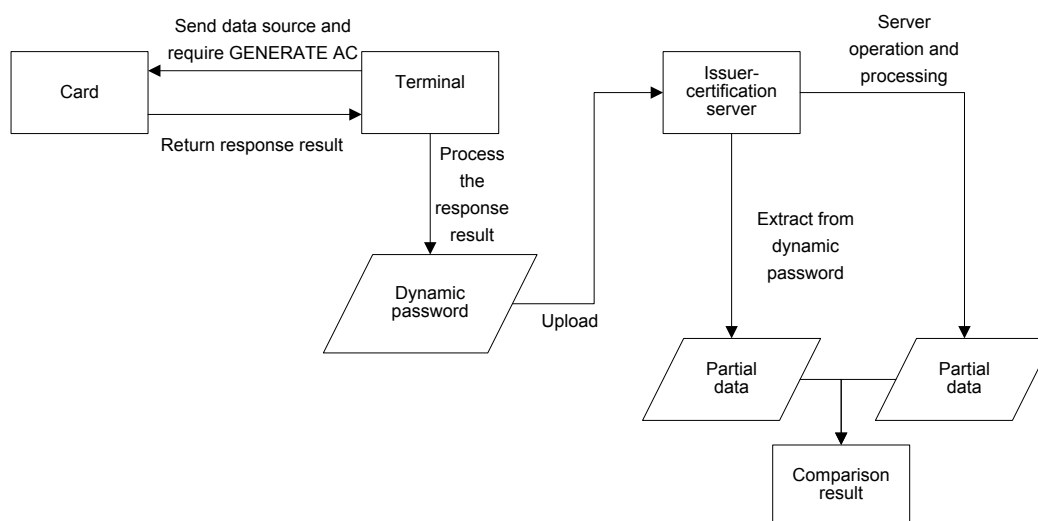


Figure1 Dynamic password authentication work principle

5.2 Card function description

Major function of financial IC card in the process of generating dynamic password is to calculate the data sources sent by card reader terminal according to GENERATE AC process and generate GENERATE AC response including application cryptogram. The process is in line with relevant processes and requirements of the UICS Specifications.

The detail is shown below:

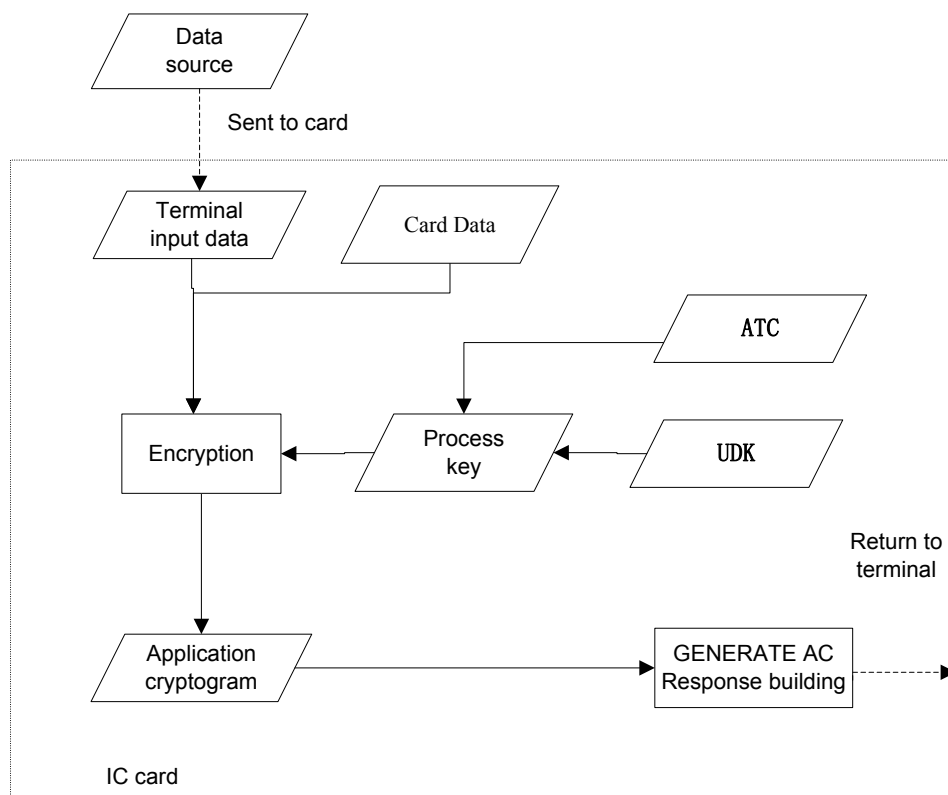


Figure2 Working principle of card

After receiving the data source sent by terminal, card will take the data source as input data and start the GENERATE AC process. Card uses UDK to generate process key KS with the participation of ATC. Then card uses KS to execute encryption operation of data D from terminal and relevant data in card to generate application cryptograph. Card builds response to GENERATE AC including CID, ATC, AC and IAD and returns response to terminal.

5.3 Card Reader Terminal Working Principle

Terminal is mainly responsible for providing source data and initiating GENERATE AC process to card in the process of generating dynamic password, and executing compression and conversion after receiving GENERATE AC response to obtain dynamic password used in authentication which is visible to users.

Detail is shown below:

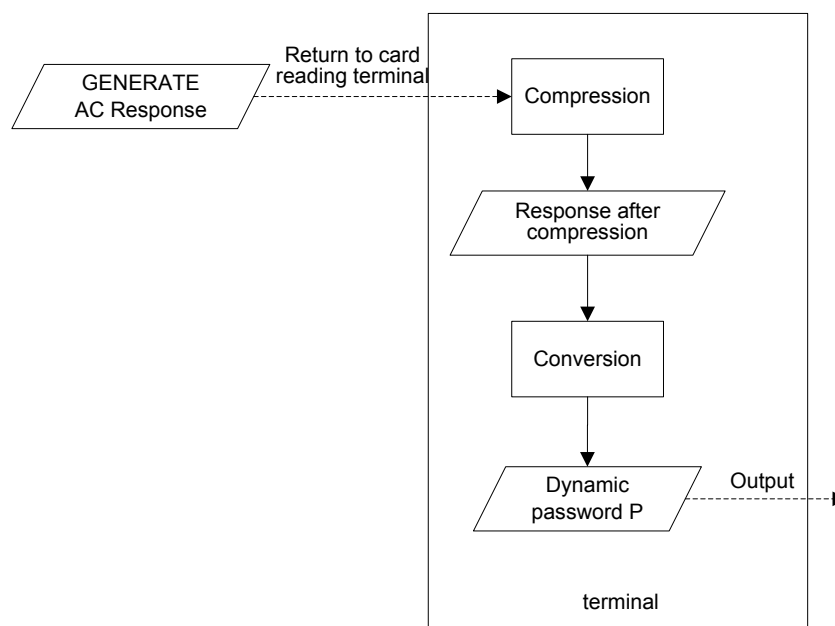


Figure3 Working principle of card reader terminal

After receiving GENERATE AC response from card, terminal compresses response results and select significant digit in the sections of ATC, AC and CVR to constitute a dynamic password and generate compressed response. Then performs conversion, including shifting operation based on bit and the process of conversion to decimal number, and finally generates dynamic password P which could be used by user for authentication.

5.4 Issuer Authentication Working Principle

After receiving the financial IC dynamic password, the issuer must systematically process and compare the dynamic password. The entire processing procedure includes conversion, data extraction, reconstruction of data source, generation the response of GENERATE AC , comparison the compressed AC and so on.

Detail is shown below:

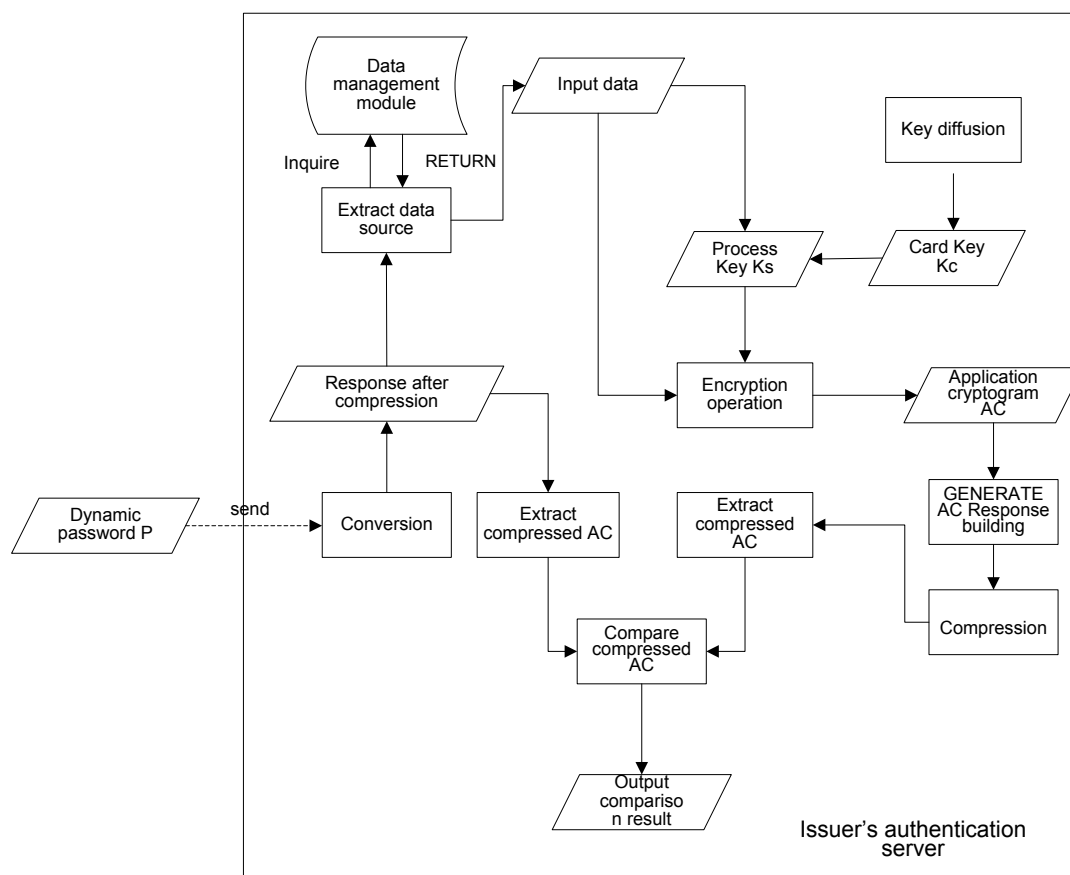


Figure4 Working principle of issuer's authentication service

After receiving dynamic password P, issuer's authentication server converts P, and the process is the inverse operation of conversion process in the terminal (refer to Section 8: Construction and display of dynamic password), generating the significant digit of dynamic password.

The server extracts ATC and CVR parts from the significant digit of dynamic password, and inquires other information required for constituting data source to data management module and takes the completed data source as input data.

At the same time, authentication server of the issuer inquires corresponding master key K_M to bank PIN machine using the user account number or card number sent by application server, and K_M is used to perform key diffusion and generates card key (Kc). Kc generates the process key Ks according to specified algorithm, then Ks is used to perform encryption operation for specified data, generating application cryptogram AC.

Finally, the server compares the AC part in the compressed response derived from dynamic password P with the AC part derived from authentication server and outputs the comparison result.

6 Business Process

This section outlines the business process of card reading terminal. Business flow chart illustrates the execution order of devices operating financial IC card.

6.1 Function Overview

The following are functions used in the process of card reading terminal operating the IC card. The entire operation process of IC card meets UICS Specifications and simplifies the process according to the particulars of card reading terminal.

6.1.1 Application Selection

At present, card reading terminal definitions are meant for use with contact debit/credit financial IC card. Therefore, card reading terminal must select a UICS debit/credit application.

6.1.2 Initialization of Application

After selecting a UICS debit/credit application, card reading terminal conducts application initialization. Card reading terminal informs of the beginning of the transaction process by sending GPO command to card. In the command, card reading terminal provides the data elements requested in PDOL to the card. PDOL (a list of tags and length of data elements) is an optional data item returned to card reading terminal from card in application selection processing.

The response data to GPO command from card includes AIP and AFL. AIP lists the functions executed in processing of transaction; AFL lists the short file identifier stored in the data that shall be read by transaction, record number, record quantity and the storage location of static signature data needed for offline data authentication.

6.1.3 Reading Application Data

Card reading terminal reads corresponding record according to AFL and analyzes CDOL1 and CDOL2 for the use of follow-up transaction flow.

6.1.4 Terminal Action Analysis

In the transaction process of visiting IC card, card reading terminal simplifies the analysis of standard debit/credit terminal behaviors. Card reading terminal sends request of offline denial operation to IC card and applies for AAC.

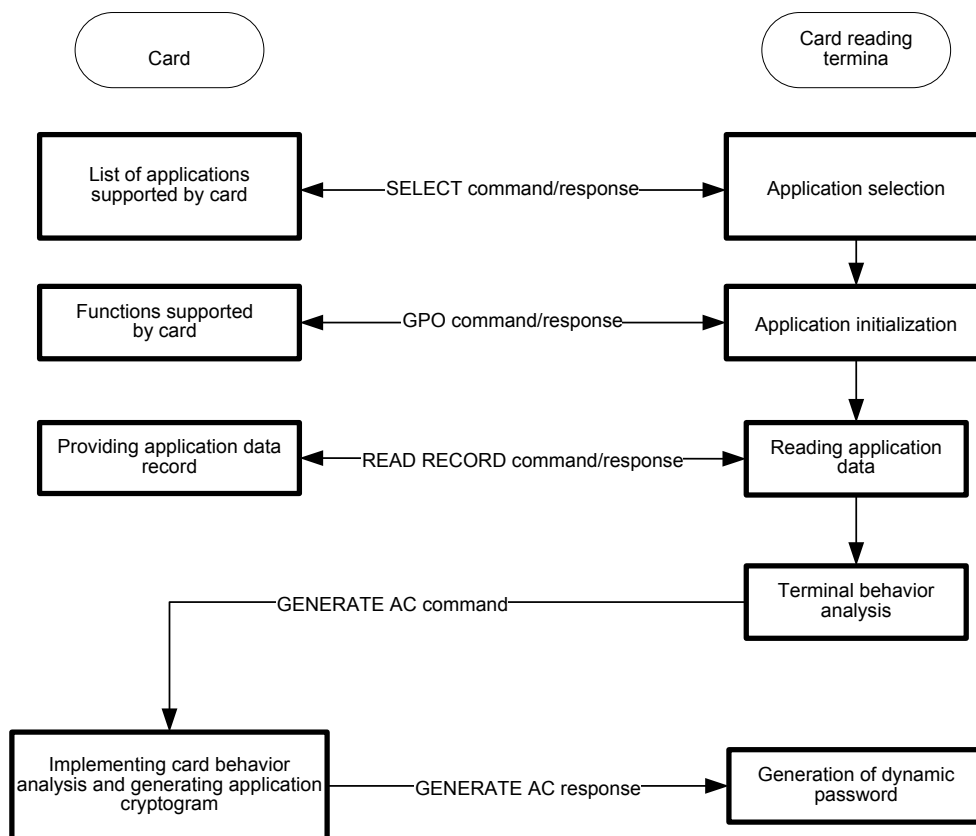
6.1.5 Generation of Dynamic Password

After receiving the first GENERATE AC command, card conducts card action analysis and returns response data of GENERATE AC command to terminal; the application cryptogram returned by card shall be AAC. When card successfully returned AAC, card reading terminal calls dynamic password generation algorithm to generate dynamic password and display it.

6.1.6 Transaction Completion

Since terminal requests offline denial (AAC) in the first GENERATE AC command, the transaction ends normally after responding to the first GENERATE AC command and returning AAC.

6.2 Transaction Flow Chart



7 Instruction and Implementation Instructions

7.1 Application Selection

7.1.1 Command Select

Card reading terminal sends SELECT command to card to select standard debit/credit application and obtains application data supported by card. Application data includes issuer parameters, such as priority level of application selected, name of application and first choice language. Command shall include standard debit/credit AID.

P1 parameter in the command indicates that applications are selected by name. P2 parameter indicates whether there are applications using the same AID being requested under the condition of supporting AID suffix (when card supports multiple applications using the same AID).

Command shall have the following SW1 SW2 return state word:

——9000—— SELECT command successfully returned;

——6A82——if command includes name of payment system environment, card does not support the mode of directory selection; If command includes AID, it shows that file selected are not found or it's the last file with the same AID, while P2 parameter specifies there is still application with the same AID available for use.

——6A81——card blocked or command not supported;

——6283——invalid file selection.

If card includes a PDOL, as a part of FCI, PDOL shall be included in the response data of SELECT command. During initialization processing of application, card reading terminal sends designated data in PDOL into card.

After successful return of select command, card reading terminal continues to conduct follow-up transaction flow. In case of unsuccessful return of select command, card reading terminal shall immediately terminate the transaction flow and prompt user of transaction failure.

7.1.2 Relevant Follow-on Flows

Application initialization

Card reading terminal sends the GPO command to card; if the response data of select command during application selection includes PDOL, GPO command shall include terminal data designated in PDOL. If some restrictions do not allow initialization of selected application, card reading terminal shall immediately terminate the transaction procedure and prompt user of transaction failure.

7.2 Application Initialization

7.2.1 Command

Card reading terminal informs of the beginning of card transaction by sending GPO command to card during initialization of application. In the command, card reading terminal provides the data elements requested in PDOL to the card. PDOL (a list of tags and length of data elements) is an optional data item returned to card reading terminal from card in application selection process.

The response data to GPO command from card includes AIP and AFL. AIP lists the functions executed in processing of transaction; AFL lists the short file identifier stored in the data that shall be read by transaction, record number, record quantity and the storage location of static signature data needed by offline data authentication.

7.2.2 Processing Flow

Card reading terminal reads FCI data returned by SELECT command of application selected and analyzes it for PDOL.

Card reading terminal processes PDOL and fills in terminal data according to processing rules of DOL.

Card reading terminal sends GPO command to card and sends terminal data from processing of PDOL as command data in the format of TLV (tag 83) to card. If PDOL doesn't exist, command data field shall be 83 00.

If card returns successfully (SW1 SW2="9000"), card reading terminal reads AIP and AFL, then conducts subsequent reading of application data.

If card fails to return GPO command, card reading terminal shall immediately terminate the transaction and prompt user of transaction failure.

7.2.3 Relevant Pre-processing

Application selection

Card provides PDOL (if any) in response to select command as a part of FCI to terminal.

7.2.4 Relevant Post-processing

Reading application data

Card reading terminal uses AFL included in GPO command response provided by card to determine to read which application data to analyze CDOL1 and CDOL2.

7.3 Reading Application Data

7.3.1 Command

Card reading terminal sends Read Record command to card to read record data. Command parameter P2 includes SFI of files that shall be read while P1 is the number of record read. If return-state SW1 SW2 is 9000, then response data field includes record data requested.

7.3.2 Processing Flow

Card reading terminal determines which transaction data records from card to read through AFL, and each AFL item (4 bytes) represents the continuous record in each file of card. For each AFL item (4 bytes), card reading terminal sends a read record command to card to read Record data from the first record until the last. Thus all AFL items are handled. Card reading terminal analyzes CDOL1 and CDOL2 from data read for the use of follow-up transaction flow.

In case of the following circumstances during reading of data, transaction will be suspended:

- One basic data object appears more than one in card;
- Card lacks CDOL1 and CDOL2 data;
- Wrong data format;
- Return state word of READ RECORD command is not “9000”.

7.3.3 Relevant Pre-processing

Initialization of application

Card reading terminal obtains AFL of application from response of GPO command to read application data.

7.3.4 Relevant Post-processing

Terminal action analysis

7.4 Terminal Action Analysis

7.4.1 Overview

In the transaction process of visiting IC card, card reading terminal simplifies the analysis of standard debit/credit terminal behaviors. Card reading terminal sends online request to IC card and applies for AAC instruction.

7.4.2 Command

Card reading terminal sends the first Generate AC instruction to card and sets P1 parameter of command as 0x00. The Data field of command shall be combined according to the data order defined by CDOL1.

7.4.3 Processing flow

Simplifying standard debit/credit terminal behavior analysis flow and sending Generate AC to card to request AAC instruction.

7.4.4 Pre-processing

Reading application data

Card reading terminal reads application data from card. Data includes card risk management data object list 1 (CDOL1) and card risk management data object list 2 (CDOL2).

7.4.5 Post-processing

Generation of dynamic password

In analysis of card behavior, card executes additional risk management to determine whether to agree the online request of terminal. If card requests online, card reading terminal will call dynamic password generation algorithm to generate dynamic password and display it.

7.5 Generation of Dynamic Password

7.5.1 Command

Card returns the response data of GENERATE AC command at the end of card action analysis, and the application cryptogram returned by card could only be AAC. For details, refer to return of UICS Basic Specification Part 5 GENERATE AC command format I.

7.5.2 Processing Flow

After receiving the first GENERATE AC command (requesting AAC), card will conduct card action analysis according to standard debit/credit transaction flow and return response data.

Card reading terminal judges card response data and terminates transaction in case of any one of the following circumstances:

1. Wrong data format returned by card.
2. Failure in returning GENERATE AC command.

If card successfully generates and returns AAC, card reading terminal calls dynamic password generation algorithm (including compression) to generate dynamic password and display it.

7.5.3 Pre-processing

Reading application data

Card reading terminal reads card risk management data object list 1 (CDOL1) from card.

Card reading terminal requests AAC to card according to result of terminal behavior analysis and provides terminal data requested in CDOL1 to card.

7.5.4 Post-processing

Transaction completion

7.6 Transaction Completion

7.6.1 Overview

After generation and display of dynamic password, the operation of IC card by card reading terminal in this transaction is completed.

7.6.2 Pre-processing

Card action analysis

Card returns AAC in the response to the first GENERATE AC command.

7.7 Data Required in Transaction Process

7.7.1 Definition of data involved in CDOL1, CDOL2 and PDOL

Data element	Data from terminal	Data within card	Data Sources
Authorized amount	V		Keyboard input (event type defaulted as full 00) (6 bytes)
Other amount	V		Fixed 000000(6 bytes)
Terminal country code	V		Fixed 0156
Terminal verification result	V		Fixed 0000000000
Transaction currency code	V		Fixed 0156
Transaction date	V		Fixed 000000
Type of Transaction	V		Fixed 0
Unpredictable number	V		Keyboard input (event type defaulted as full 00) (4 bytes)
Application Interchange Profile (AIP)		V	

Data element	Data from terminal	Data within card	Data Sources
Application transaction counter (ATC)		V	
Card verification result (CVR)		V	

Besides the data elements listed above, if CDOL1, CDOL2 and PDOL also include other data parameters, the default value could be 0.

7.7.2 CVR Data Definition

Byte 1: fixed as 3

Byte 2:

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	Description
1	0							Not requesting the second GENERATE AC
		0	0					The first GENERATE AC returns AAC
				0				Issuer authentication executed but fails
					0			Offline PIN execution
						0		Offline PIN authentication fails
							0	Cannot go online

Byte 3

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	Description
X								Last online transaction not completed
	0							PIN blocked

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	Description
		X						Over frequency check
			0					New card
				X				Over frequency check
					X			After online authorization, issuer authentication not executed
						0		Block card and application due to PIN
							0	SDA of last transaction fails, transaction denied

Byte 4

Bit8	Bit7	Bit6	Bit5	Bit4	Bit3	Bit2	Bit1	Description
0	X	X	X					Issuer script command with security cryptogram received after generation of the second application cryptogram command in the last transaction
				X				Issuer script processing failure indicator of the last transaction
					0			DDA of the last transaction fails, transaction denied
						0		DDA execution
							0	RFU(0)

8 Dynamic Password Structure and Display

8.1 Encryption Algorithm

All the key derivation algorithms and encryption algorithms in the card and issuer authentication servers involved in the specification shall comply with relevant requirements of *UICS Specifications*.

8.2 Construction of Relevant Data for Dynamic Password

Dynamic password mentioned in the specification is constituted by selecting the valid bit in GENERATE AC response through conversion.

Overall length of GENERATE AC response is at least 18 bytes (including one byte of CID, 2 bytes of ATC, 8 bytes of AC and 7 bytes of IAD); the length of IAD only takes length indicator, scattered key index, cryptogram version No. and card verification result, for example length of IAD in GENERATE AC response is larger than 7 bytes, and the specification only selects the 7 bytes in the front.

Detailed structure is shown as follow:

GENERATE AC response of the structure	CID	ATC	AC	IAD
--	-----	-----	----	-----

8.3 Valid Bit selection of Dynamic Password

According to the requirement of dynamic password, selecting the corresponding data from the response of GENERATE AC, and then reassembling according to the original data to form the valid bits of dynamic password.

The valid data selected in the specification is shown in the chart below. After conversion from hexadecimal to binary, the corresponding 1 bit positions are valid bits:

<u>00</u>	<u>7F FF</u>	<u>FF FF 00 00 00 00 00 00</u>	<u>00 00 00 00 00 AC 78</u>
CID	ATC	AC	IAD

As shown in the table above, there are 15 valid bits in ATC part, equaling to a counting cycle including 32767 transactions; there are 16 valid bits in AC part, i.e. the first two bytes in AC; there are 8 valid bits¹ in IAD part, all in CVR. There are 39 bits in total

¹ The 8 valid bits of the CVR part chosen in this Specification is only the basic requirement for financial IC card dynamic password applications, and the Issuer can add valid bit length based on individual risk profile and product personalization needs, whereby the length of the dynamic password generated will also increase accordingly.

8.4 ATC XOR

In order to avoid having 0 in the first several bits of ATC for newly issued cards, resulting in generated dynamic password of insufficient randomness in the initial digits, this specification requires an ATC XOR calculation prior to use in the construction and display of dynamic password.

Conducting XOR operation for the first 15 bit data (high-order in front) in ATC part (15 bits) and AC part (16 bits), and the data obtained is the new data of ATC part.

For example:

Original ATC: 1001 1100 0011 010

AC: 1100 0101 1000 0011

The first 15 bits of AC used for XOR operation: 1100 0101 1000 001

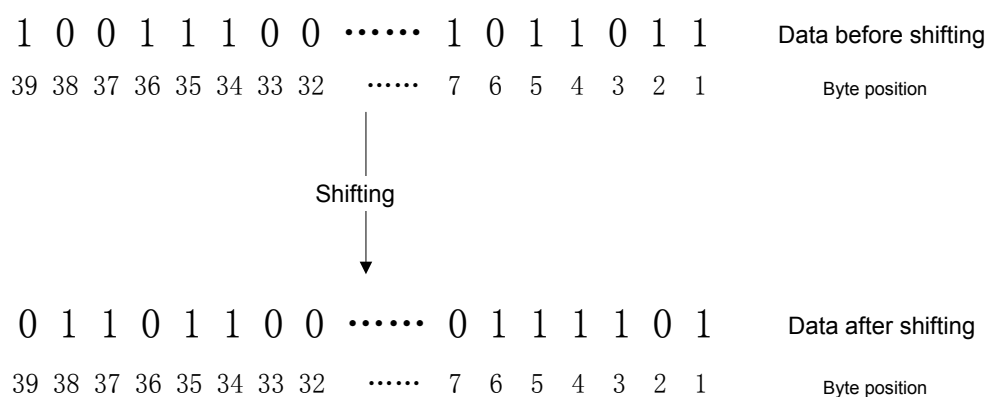
ATC after XOR operation: 0101 1001 1011 011

Then, according to the GENERATE AC responding format in 8.3, re-combining ATC, AC and CVR again, finally obtaining the valid data of dynamic password.

8.5 Shifting Rule for Valid Bits

In order to improve the randomness of dynamic password, this specification requires the shift of valid bits of dynamic password before display.

Shift method: Exchange the odd digit position with even digit position on the right among the 39 bits (no action for the first bit position), as shown in the table below:



As shown in the table above, no action for the first bit position, third bit exchanged with the second bit position; apply the same movement operation until the 39th position, i.e. till exchanging the 39th bit position with the 38th bit position. After shifting operation, the data obtained is the data of dynamic password.

8.6 Dynamic Password Display

Card reading terminal converts binary digit into decimal digit after shift, and finally, 39 bits of binary digits will be displayed as 12 decimal digits. Different display methods may be chosen: as 12 digits are long, we could convert into duotrigesimal digit (in the form of digits and letters) to display on the screen, which can be expressed in 8 digits and convenient for cardholders it could also support longer valid bits, but not applicable for input via telephone keyboard. The principle shown below:

- a. 39 designated digits convert into a digit from low order to high order every five digits.
- b. The above digits are expressed with the following duotrigesimal digits:

Decimal digit	0	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15
Duotrigesimal digit	0	1	2	3	4	5	6	7	8	9	A	C	D	E	F	G
Decimal digit	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31
Duotrigesimal digit	H	J	K	L	M	N	P	R	S	T	U	V	W	X	Y	Z

- c. Note: in order to avoid cardholders confusing characters with numbers, character B (same as digit 8), I (same as digit 1), O and Q (same as digit 0) are excluded.
- d. In this manner, the number of valid bits can be appropriately increased.

9 Issuer Authentication Service

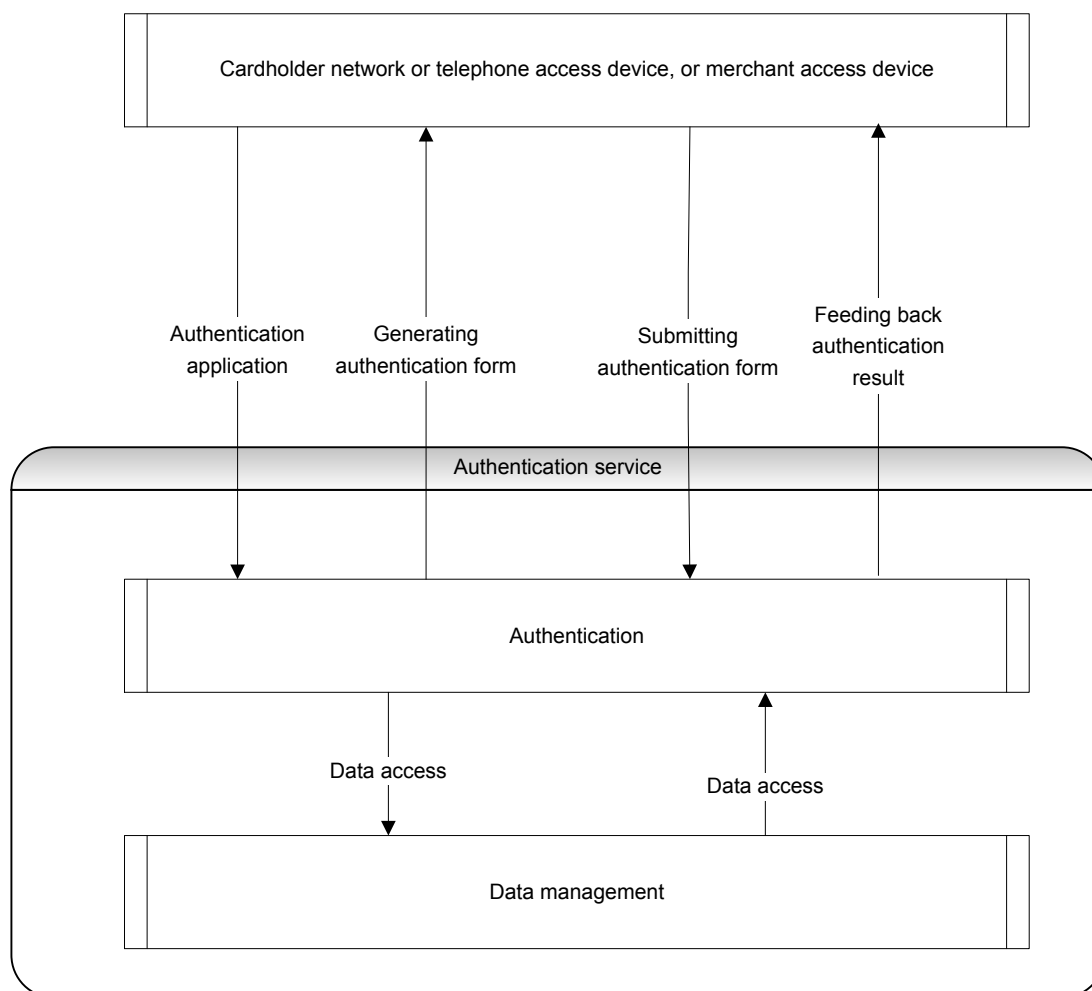
9.1 Introduction of Authentication Service

Issuer authentication service refers that issuer verified the authenticity of dynamic password generated by financial IC card on handheld terminal and it's is composed of the following functions:

- **Data management** - stores and maintains card data required by verifying dynamic password, including keys for calculating AC.
- Accepting authentication request.
- Verifying dynamic password.
- Responding with authentication results.
- According to different modes, authentication service could also generate cardholder authentication form.

Cardholder authentication form refers to the data that the cardholder needs to fill in for the current transaction, such as dynamic password, transfer amount, account number, etc. Authentication service generates authentication form and sends it to network access equipment of cardholders. Cardholders need to fill in relevant data, including dynamic password and submit the data to authentication service. If it's telephone order, then merchant shall complete authentication form on behalf of cardholder.

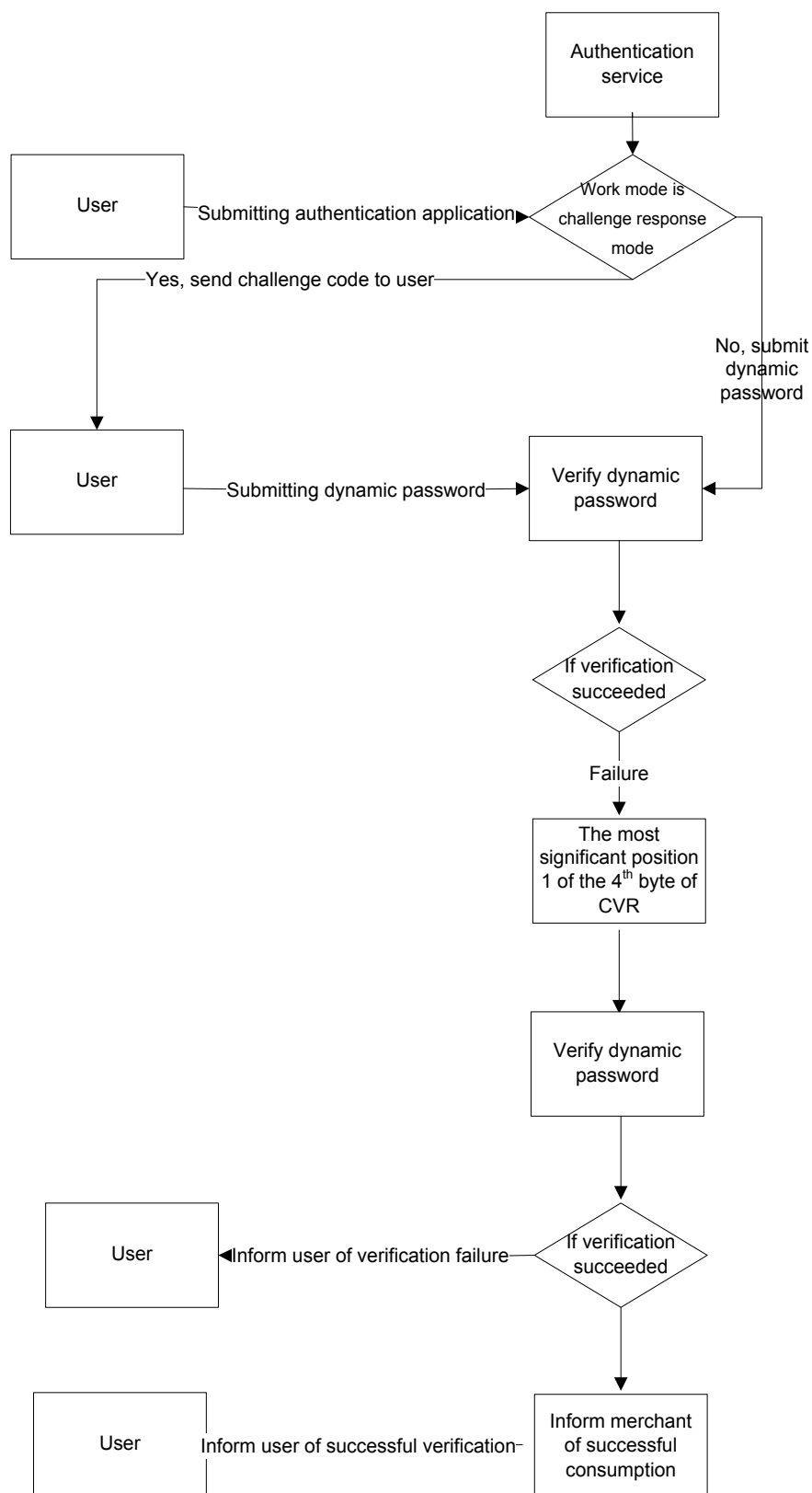
9.2 Basic Framework Diagram of Authentication Service



Cardholder submits authentication application to authentication service through network or telephone access device, authentication service could generate authentication form selectively (authentication data that needs to be filled in, such as account number and transaction amount); user fills in authentication form (including dynamic password) and submits the form to authentication service; after verification, authentication service returns result to user.

During the verification process of authentication service, card data required can be accessed through data management.

9.3 Authentication Server Reference Flowchart



For the operation of verifying dynamic password in the above chart, please refer to Section 5.4 authentication principle for details.

9.4 Loss of Synchronism Processing

Limited by length, the most significant digit in digit 4 of card data CVR is not uploaded when uploading dynamic password and it's defaulted as 0. If the digit is 1, it will cause failure in verification of authentication service. In order to solve the problem, authentication service will re-verify the digit 1 when the first verification of authentication service fails. If verification failed twice, then authentication service will return result to user.

9.5 Data Management

9.5.1 Card Data

TAG	value	Source
CID	0x80	Default value
CVN	N/A	Issuer, obtained through data management
DKI	N/A	Issuer, obtained through data management
AIP	N/A	Issuer, obtained through data management
ATC	N/A	Dynamic password upload
CVR	N/A	Some are default values, dynamic passwords partially uploaded

Detailed description of CVR as follows:

Card verification result (CVR) F: b 32 T: – L: 4.	Byte 1: length byte 03	Default value 0x03
	Byte 2:	
	bits 8–7:	Default value 0x10
	00 = the second GENERATE AC returns AAC 01 = the second GENERATE AC returns TC 10 = not requesting the second GENERATE AC 11 = RFU	
	bits 6–5:	Default value 0x00
	00 = the first GENERATE AC returns AAC	

	01 =the first GENERATE AC returns TC 10 = the first GENERATE AC returns ARQC 11 =can't return 11 bit 4: 1=Issuer authentication executed but failed bit 3: 1 =offline PIN executed bit 2: 1 = offline PIN authentication failed bit 1: 1 =Cannot go online	Default value is 0 Default value is 0 Default value is 0 Default value is 0
Card verification result (CVR) (continued)	Byte 3: bit 8: 1 = last online transaction not completed bit 7: 1 = PIN blocked bit 6: 1 = Over frequency check bit 5: 1 = new card bit 4: 1 = issuer authentication of last online transaction failed bit 3: 1 = after online authorization, issuer authentication not executed bit 2: 1 = application blocked due to pin locking card bit 1: 1 = last transaction SDA failed, transaction denied Byte 4: bits 8–5: issuer script command with security cryptogram received after the second GENERATE AC command of last transaction bit 4: 1 = last transaction issuer script processing failed indicator bit 3: 1 = last transaction SDA failed, transaction denied bit 2: 1 = DDA execution bit 1: RFU (0)	Uploaded by dynamic password Default value is 0 Uploaded by dynamic password Default value is 0 Uploaded by dynamic password Default value is 0 Uploaded by dynamic password Default value is 0 Default value of Bit8 is 0 Bit 7-5 uploaded by dynamic password Uploaded by dynamic password Default value is 0 Default value is 0 Default value is 0

9.5.2 Terminal data

Refer to 7.7.1. Definition of data involved in CDOL1, CDOL2 and PDOL

9.6 Algorithm

Algorithms involved by authentication server include algorithm of calculating application cryptogram, process key algorithm, compression algorithm and shift algorithm.

Algorithm of calculating cryptogram:

Refer to Appendix D in Basic Specification Part 4 of UICS Specifications.

Process key algorithm:

Refer to Appendix C in Basic Specification Part 4 of UICS Specifications.

Compression algorithm:

Refer to Chapter 8 Construction and Display of Dynamic password in this specification.

Shift algorithm:

Refer to Chapter 8 Construction and Display of Dynamic password in this specification.

9.7 Risk Management

In order to further strengthen the security of dynamic password and avoid dynamic password used illegally if obtained in advance, issuer shall judge the ATC submitted by dynamic password each time, which is also the time of transactions; criterion of judgment shall be that ATC of the transaction must be greater than ATC forwarded by the last dynamic password transaction or online transaction (POS, ATM); if failing to satisfy this condition, verification will be unsuccessful and cardholder will be required to regenerate dynamic password until ATC is larger than ATC of the last transaction, then verification will be successful.

When ATC submitted by dynamic password is smaller than ATC of the last transaction recorded in the system, it's suggested that issuer should contact with cardholder to confirm whether the card is used by him/her.

In order to further enhance verification of the current transaction, it's suggested that issuer should adopt complicated application mode (like: challenge mode or transaction signature mode, refer to Appendix) to generate dynamic password for large amount transactions and batched transactions.

10 Other Requirements

10.1 Card Reader Hardware Requirements

10.1.1 Display Screen

Display screen displays dynamic password digits or characters at the same time.

10.1.2 Input

It shall have the ability of inputting 10 digits and corresponding error correction and confirmation abilities in terms of function.

Equipped with mode switch function input, convenient for users to switch in different dynamic password modes.

10.1.3 IC card Reader

Contact IC card socket is required to accept user IC card insert and conduct command data transmission and communication with IC card.

It's suggested that the area near IC card reader slot should have a distinct sign indicating how to insert IC card. If card reader has the function of locking card, it shall guarantee card release in case of power down, device exception or transaction cancellation.

It shall also support t=0 and t=1 card.

10.1.4 Battery

Card reading terminals shall have battery and it's suggested to use commonly used battery types.

10.2 Card Reader Software Requirements

It shall have the function of self-checking software and hardware, and the function of card detection and powering up for operation.

The time interval from final confirmation entry to the time of displaying dynamic password shall not exceed 2s.

10.3 Card Reader Security Requirements

Since the application environment of the device is without entry of sensitive data (such as PIN and card number) and storage of critical data, and due to independence of application environment (there is no interactive link of external data except interacting with IC card), card reader doesn't need special security level for guarantee.

Must comply with ISO/IEC 7816 and EMV standard.

10.4 Balance Inquiry

Card reading terminal shall have electronic cash balance inquiry function.

Appendix A Application mode recommendation

This section describes three recommended authentication modes for financial IC card dynamic password: event authentication mode, challenge authentication mode and signature transaction mode for reference.

A.1 Event (or default) Authentication Mode

Refers to the mode in which cardholders or issuer is not required to intervene or provide input data and directly generate dynamic password through default data. Usage is very simple, and therefore suitable for simple login inquiries or low risk customers.

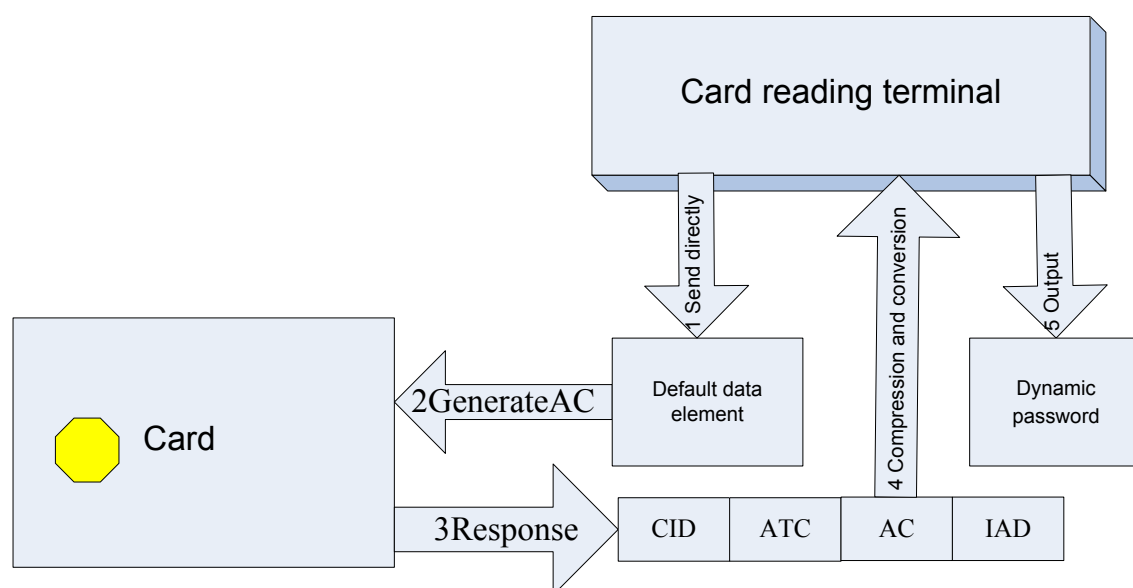


Chart 5: Event authentication working principle

Users don't need any external data input operation for each authentication request and card reading terminal sends preset default data element (refer to Appendix 1) to card to conduct Generate AC operation. Card returns ATC and application cryptogram AC to card reading terminal and card reading terminal compresses and converts the data obtained to get dynamic password.

The data that card reading terminal sends to card shall all be default value:

Default data element	Data from terminal
Authorization amount	Default value
Other amount	Default value
Terminal country code	Default value
Terminal verification result	Default value

Default data element	Data from terminal
Transaction currency code	Default value
Transaction date	Default value
Type of Transaction	Default value
Unpredictable number	Default value

A.2 Challenge Authentication Mode

Cardholders or issuer shall provide input data and card will generate dynamic password according to input data. This mode is more secure and is suitable for use by common merchant purchases.

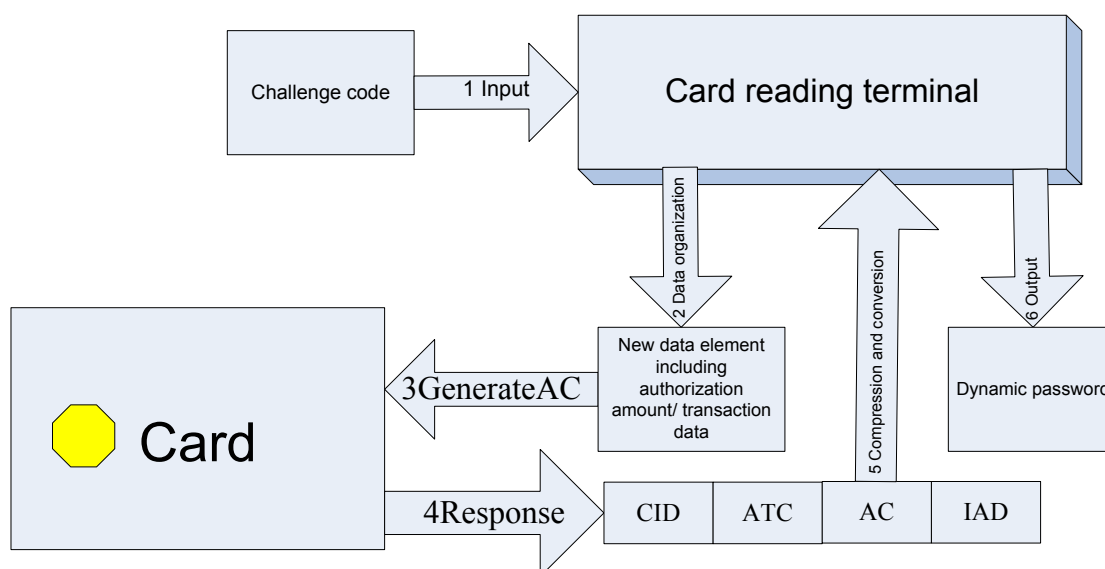


Chart 6: Challenge authentication working principle

Users input challenge code provided by issuer according to prompts in each authentication request, and challenge codes are mostly random digits. Card reading terminal reorganizes data elements after obtaining the challenge code entered and replaces unpredictable digit field of default data element with the challenge code entered. Card reading terminal sends the reorganized new data to card for Generate AC operation. Card returns ATC and application cryptogram AC to card reading terminal and card reading terminal compresses and converts the data obtained to get dynamic password.

Assuming the challenge code is 1234 (not exceeding 8 decimal digits, adding 0 in front if less than 8 digits)

Default data element	Data from terminal
Authorization amount	Default value
Other amount	Default value
Terminal country code	Default value
Terminal verification result	Default value
Transaction currency code	Default value
Transaction date	Default value
Type of Transaction	Default value
Unpredictable number	00001234

A.3 Transaction Signature Mode

Transaction signature mode can be divided into two classes according to different data contents entered; one is input transaction data, the other is input transfer account number information, or ID number or order number, which is suitable for security authentication of large amount transaction or specific circumstances.

Users input authorization amount according to prompts in each authentication request. Card reading terminal reorganizes data elements and replaces authorization amount field of default data element with the authorization amount entered. Card reading terminal sends the reorganized new data to card for Generate AC operation. Card returns ATC and application cryptogram AC to card reading terminal and card reading terminal compresses and converts the data obtained to get dynamic password.

Authorization amount: numeric, in basic unit of cent, in the format of n12.

n-numeric type, also called BCD code. Right alignment, adding 0 on the left. For example, digit 123.45 can be stored in the authorization amount data object of n12, such as '00 00 00 01 23 45'.

If authorization amount is 123.45 Yuan, the data source sent to card shall be:

Default data element	Data from terminal
Authorization amount	000000012345
Other amount	Default value
Terminal country code	Default value
Terminal verification result	Default value

Default data element	Data from terminal
Transaction currency code	Default value
Transaction date	Default value
Type of Transaction	Default value
Unpredictable number	Default value

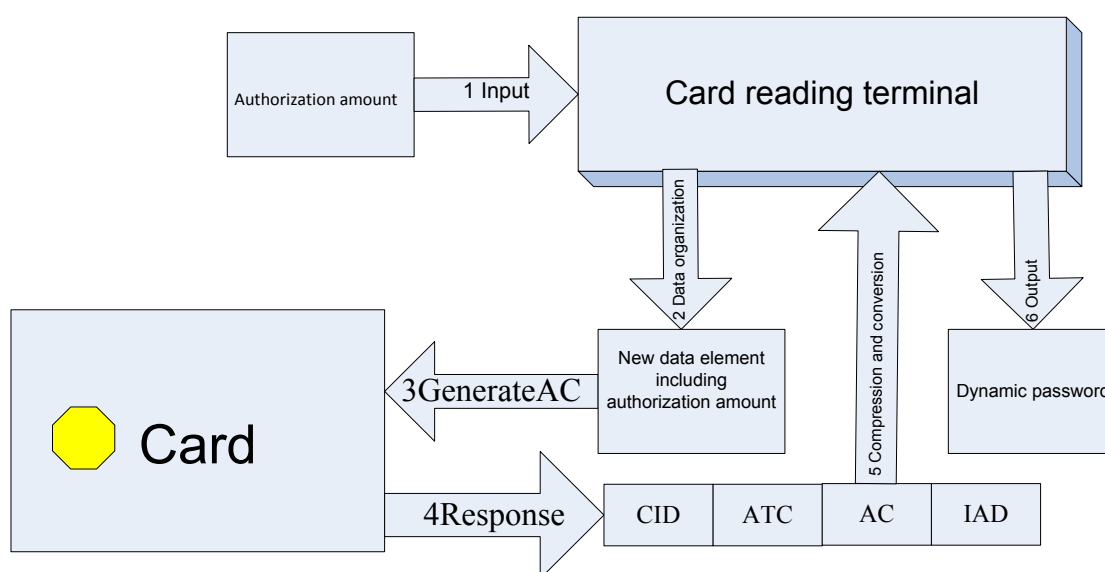


Chart 7: transaction data authentication working principle

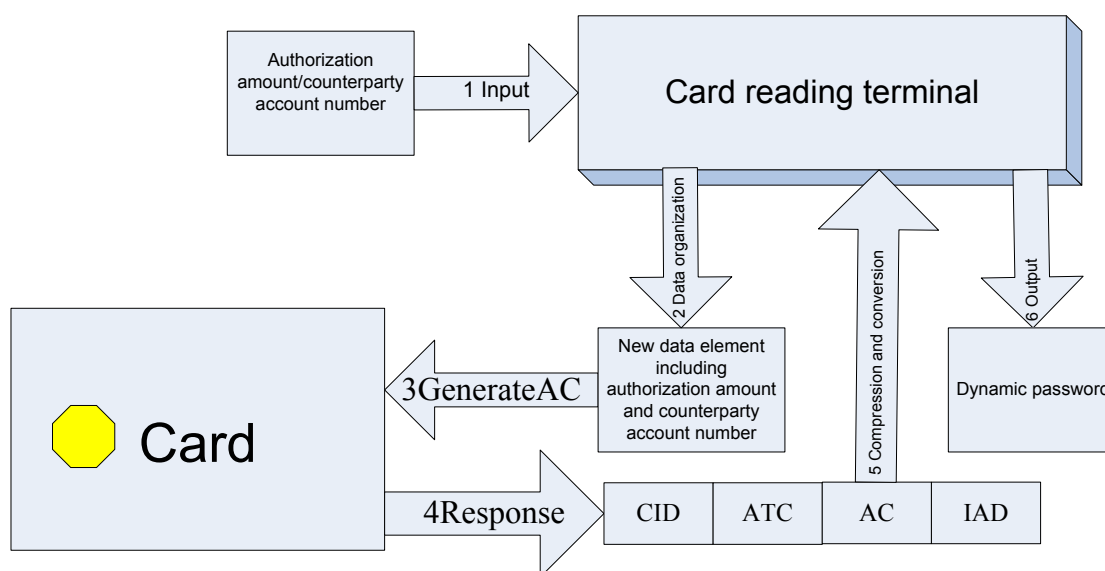
A.4 Input transfer account

In order to effectively prevent phishing site fraud, a transaction signature mode is added for transfer and the information of transfer-in account number (all or part) is also included into signature data. During transfer process, the last 8 digits of card number of counterparty shall be filled into the field of Unpredictable Number in data source for calculation of AC. Card reading terminal sends new data after organization to card for Generate AC operation. Card returns ATC and application cryptogram AC to card reading terminal and card reading terminals will obtain dynamic password after compression and conversion of data obtained.

Assuming the account number for transferring RMB 498 to counterparty is 6226100200311400567, then the data source sent to card shall be:

Default data element	Data from terminal
Authorization amount	000000079800
Other amount	Default value

Default data element	Data from terminal
Terminal country code	Default value
Terminal verification result	Default value
Transaction currency code	Default value
Transaction date	Default value
Type of Transaction	Default value
Unpredictable number	1400567



A.5 Application example:

Cardholder logs on online banking to conduct funds transfer:

- Cardholder enters transfer account name and transfer amount on the page
- Bank requires cardholder to use dynamic password to confirm his/her funds transfer
- Cardholder inserts PBOC financial IC card into dynamic password generator
- Cardholder presses transfer signature PIN generation key on the keyboard
- Bank prompts cardholder to enter transaction parameters, such as transaction amount and account number of counterparty
- Cardholder enters parameters into dynamic password generator

- UnionPay financial IC card generates a dynamic and unique transaction signature which can't be used repeatedly
- Transaction signature will be displayed on the screen of dynamic password generator after conversion by terminal into digits
- Dynamic password entered into online banking by cardholder
- Issuer of cardholder verifies whether the dynamic password is legal
- Transaction completes funds transfer legally and transaction ends